

VM Risk Agent: Rubric Design

Design rationale for the agent's scoring rubric: components, math, and source material.

Keisha Isaacs · May 2026 · Version 1.0

Overview

The VM Risk Agent takes a Tenable scan and a structured analyst interview to produce a ranked remediation report. The rubric exists to go a step further than CVSS by re-ordering findings based on what an organization needs, what it can realistically defend, and what it is exposed to. The rubric draws on two source texts. Andrew Magnusson's *Practical Vulnerability Management* [1] supplies the structural moves of a VM analyst: cull, rank, weigh risk against cost, and account for organizational friction. Rick Howard's *Cybersecurity First Principles* [2] supplies the probabilistic framing: Fermi-estimated priors, Bayesian adjustment by deployed defenses, and forecasting honesty as a first-class output.

Two-Stage Pipeline

Every finding moves through a cull stage and a rank stage. The cull stage is a binary filter that removes findings not currently worth analyst attention: informational severity, CVSS below 4.0 with no known exploit, assets the interview flagged as out of scope, and findings the interview marked already mitigated. The cull/rank distinction follows Magnusson's framework [1, ch. 1]. Findings that survive the cull are scored on a 0.0 to 1.0 scale and assigned a priority bucket (Critical, High, Medium, Low). Score computation is deterministic and runs in Python. The language model generates the rationale text that accompanies each score but does not produce the number itself. That split preserves auditability and reproducibility: same inputs always yield the same score.

Scoring Formula

Each surviving finding is scored using the following composition:

```
cvss_norm = CVSS / 10
headroom = 1.0 - cvss_norm
base_likelihood = min(1.0, cvss_norm + headroom × (exposure_boost +
exploit_boost))
material_cost = (asset × 0.4) + (data × 0.4) + (CIA × 0.2)
raw_score = base_likelihood × material_cost
adjusted_score = raw_score × (1 - defense_adjustment)
final_score = adjusted_score × org_context_modifier
```

Three concepts from the source texts shape this formula.

Risk = Likelihood × Cost is the structural backbone, taken from Magnusson [1, ch. 6]. A finding's risk is the chance of exploitation multiplied by what the organization actually loses if it happens.

A **Fermi estimate** is a back-of-the-envelope calculation that produces a useful answer when precise data isn't available. Howard treats this as the right level of precision for cyber risk, where exact probabilities can't be measured but rough magnitudes still guide better resource decisions [2, ch. 6].

Bayesian adjustment is the technique of starting with that estimated prior and lowering it based on what defenses are actually in place. Howard walks through the pattern using Contoso, Microsoft's

stand-in company for documentation [2, ch. 6].

The formula combines all three. CVSS, exposure, and exploit availability produce the Fermi-estimated base likelihood. Asset criticality, data sensitivity, and CIA impact produce the material cost. Their product is the raw score. The defense adjustment reduces that raw score Bayesian-style, and the org context modifier is the synthesis layer where Magnusson's argument about organizational pressures gets translated into the math [1, ch. 6].

Component Detail

Base likelihood is the chance this finding could actually be exploited. It starts with the CVSS score and adds two boosts: how exposed the asset is to attackers (internal, DMZ, or internet-facing) and whether a working exploit already exists (none, proof of concept, or weaponized). A high CVSS on an internet-facing host with a Metasploit module scores near the top of the scale; the same CVSS on an internal host with no known exploit scores meaningfully lower.

Material cost is what the organization actually loses if the finding is exploited. Asset criticality and data sensitivity carry 40% of the weight each, and the CIA impact category from the CVSS vector carries 20%. The 40/40/20 split inverts the pure-CVSS weighting on the principle that what the organization actually loses (Howard's "material impact" [2, ch. 1]) matters more than the technical CIA vector. A finding on a system holding regulated patient records costs more than the same finding on a test box.

Defense adjustment is the discount applied when the organization has real defenses in place. It sums four dimensions: patching maturity, segmentation and Zero Trust, detection and response, and resilience. The total is capped at 0.50, because no defensive posture eliminates risk [2, ch. 6]. The rubric replaces Howard's fourth strategy, Automation, with Patching, because patching is the most direct response to a specific finding and Magnusson treats it as the first option [1, ch. 5].

Org context modifier is the final tune-up. It is a weighted average of regulatory pressure (50%), uptime sensitivity (30%), and recent incident history (20%), bounded between 0.9 and 1.25 so it nudges priority without overriding the underlying risk math. This encodes Magnusson's argument that organizational pressures legitimately shape which findings should be prioritized first [1, ch. 6].

Output Buckets and Confidence

Bucket	Score range	Recommended action
Critical	0.70 – 1.00	Patch immediately; mitigate if patch unavailable.
High	0.50 – 0.69	Patch in next cycle; mitigate if blocked.
Medium	0.30 – 0.49	Patch in normal cadence; consider systemic measures.
Low	0.15 – 0.29	Track; risk-accept with documentation if cost exceeds impact.

The bucket thresholds were re-calibrated after testing the rubric against a real Tenable scan. The original values (0.80 / 0.60 / 0.35) produced too few Critical findings under realistic inputs; the current values (0.70 / 0.50 / 0.30) yield a defensible distribution across the four organizational scenarios used to validate the rubric. This kind of empirical calibration is what Howard advocates [2, ch. 6].

Recommended actions come from Magnusson's four response options: patching, mitigation, systemic measures, and risk acceptance with documentation [1, ch. 5]. The rubric stays at the action-type level

rather than prescribing specific remediations. The project's scope is ranking and explaining, not dictating execution.

Every finding's score ships with a confidence rating (high, medium, or low) derived deterministically from how the analyst answered each interview question: clean structured picks carry full weight, free-form overrides and uncertainty responses carry less. This implements the superforecaster discipline of naming uncertainty alongside the forecast itself [2, ch. 6]. When confidence falls below high, the rationale flags which interview answers drove the uncertainty and recommends re-verification.

References

- [1] A. Magnusson, *Practical Vulnerability Management: A Strategic Approach to Managing Cyber Risk*. San Francisco, CA, USA: No Starch Press, 2020.
- [2] R. Howard, *Cybersecurity First Principles: A Reboot of Strategy and Tactics*. Hoboken, NJ, USA: Wiley, 2023.